



Audit Plan

SecureCart Inc.

Team

Daniel Pereira · Diogo Larangeira · Inês Tovar
Rodrigo Rodrigues

Security Audit

Coimbra, March 2026

Contents

1	Introduction	2
2	ISO 27001 Overview	2
2.1	ISMS and the PDCA Cycle	2
2.2	Structure of the Standard	3
3	ISO 27001:2022 Domain Analysis and Statement of Applicability	3
3.1	Organizational Controls	3
3.2	People Controls	3
3.3	Physical Controls	4
3.4	Technological Controls	4
4	Audit Objectives	4
5	Audit Plan	5
5.1	Scope	5
5.2	Methodology	6
5.3	Timeline	8
A	Statement of Applicability Tables	9
A.1	Organizational Controls	9
A.2	People Controls	14
A.3	Physical Controls	15
A.4	Technological Controls	16

1 Introduction

This report presents the audit planning approach developed by our team for the security audit engagement with **SecureCart Inc.** As external security auditors, we have been engaged to assess the organization’s information security posture and evaluate its compliance with the **ISO/IEC 27001:2022** standard.

SecureCart Inc. is a **mid-sized e-commerce company** operating a high-volume digital platform that processes sensitive customer data — including **personal details** and **payment information** — on a daily basis.

Given the organization’s rapid growth and increasing exposure to cybersecurity threats, management has committed to pursuing ISO 27001 certification as a strategic initiative to strengthen its **information security management system (ISMS)** and build trust with its customers and partners.

This document outlines the **audit plan for Milestone 1**, detailing the scope, objectives, methodology and timelines of the engagement. The audit focuses on evaluating key information security domains — including **governance, access control, asset management, operational security, and third-party risk** — against the applicable controls defined in ISO/IEC 27001:2022. The findings of this planning phase will serve as the foundation for the subsequent audit execution and reporting stages.

2 ISO 27001 Overview

ISO/IEC 27001 is the leading international standard for Information Security Management Systems (ISMS). Published jointly by the International Organization for Standardization and the International Electrotechnical Commission, its most recent revision — ISO/IEC 27001:2022 — provides a structured framework for organizations to establish, implement, maintain, and continually improve the way they manage information security risks. The standard is applicable to organizations of any size or sector, and certification is recognized worldwide as a benchmark for information security maturity.

2.1 ISMS and the PDCA Cycle

An ISMS is a systematic approach to managing sensitive information, encompassing people, processes, and technology to protect the **confidentiality, integrity** and **availability** of information assets. ISO 27001 governs the ISMS through the **Plan-Do-Check-Act cycle** — organizations first plan their risk treatment approach, implement the selected controls, monitor their effectiveness and continuously improve based on the results. This ensures information security is treated as an ongoing organizational commitment rather than a one-time effort.

2.2 Structure of the Standard

The 2022 revision reorganized Annex A into 93 controls across four domains: **Organizational Controls** (37), **People Controls** (8), **Physical Controls** (14), and **Technological Controls** (34). Beyond Annex A, the standard includes mandatory clauses covering context, leadership, risk assessment, and performance evaluation.

A key output of any ISO 27001 implementation is the **Statement of Applicability** (SoA) — a document that formally identifies which controls are applicable, which have been implemented, and which have been excluded, along with justification for any exclusions.

3 ISO 27001:2022 Domain Analysis and Statement of Applicability

The following sections examine the relevance of each ISO 27001:2022 control domain to SecureCart Inc., taking into account the organization’s business model, operational context, and the nature of the information it processes. For each domain, a brief contextual overview is provided, along with the Statement of Applicability (SoA) and the corresponding audit questions, presented in the appendix A, organized by control domain.

3.1 Organizational Controls

Organizational Controls **represent the most critical domain for SecureCart**, covering governance, risk management, information classification, access control policies, supplier relationships, incident management, and business continuity. The controls in this domain are particularly relevant given SecureCart’s reliance on third-party payment gateways, cloud hosting providers, and external development contractors, as well as the organization’s need to establish formal processes for managing sensitive customer and payment data.

3.2 People Controls

This domain addresses the human factor in information security, covering pre-employment screening, security awareness training, confidentiality agreements, disciplinary processes, and the management of security responsibilities across the employee lifecycle — from onboarding to termination. For an organization of SecureCart’s size, operating across multiple departments that handle sensitive personal and financial data, ensuring that personnel obligations are clearly defined and enforced is a key audit focus.

3.3 Physical Controls

Given SecureCart’s cloud-based infrastructure and distributed workforce, the applicability of this domain is limited. The scenario provides no evidence of dedicated physical information processing facilities, with physical security responsibilities largely falling on the cloud provider. The few controls marked as applicable relate specifically to off-premises equipment and devices used by the organization’s distributed and remote workforce.

3.4 Technological Controls

This is a similarly critical domain for SecureCart given its digitally native operations, encompassing authentication, privileged access management, endpoint security, vulnerability management, logging and monitoring, cryptography, data leakage prevention, and secure development practices — all areas directly tied to the day-to-day operation of SecureCart’s custom-developed e-commerce platform and cloud infrastructure.

4 Audit Objectives

The primary objective of this audit is to evaluate SecureCart Inc.’s current information security posture and assess its level of compliance with the ISO/IEC 27001:2022 standard.

Given the organization’s reliance on cloud infrastructure, third-party service providers, and a custom-developed e-commerce platform that processes sensitive customer and payment data at scale, the audit will focus on identifying gaps between existing practices and the requirements of the standard, as further detailed in the scope and Statement of Applicability presented in Section 5.

The specific objectives of this audit engagement are:

- **Information Security Governance** — Determine whether information security policies are formally established, approved by management, and effectively enforced across the organization, ensuring that all personnel are aware of and comply with their security responsibilities, in accordance with A.5.1, A.5.2, A.5.4, and A.6.3.
- **Access Control and Identity Management** — Determine whether access to systems, applications, and sensitive data is granted, maintained, and revoked in a controlled and auditable manner throughout the user lifecycle, and whether authentication mechanisms are consistently enforced across all critical systems, in accordance with A.5.15, A.5.16, A.5.17, A.5.18, A.8.2, A.8.3, and A.8.5.
- **Asset Management** — Verify whether information assets are inventoried, classified, and managed in a manner that accurately reflects the organization’s operational environment, in accordance with A.5.9, A.5.10, A.5.12, A.5.13, and A.8.1.

- **Operational Security and Incident Management** — Assess whether security monitoring, logging, vulnerability management, and incident response controls are implemented and operationally effective, in accordance with A.5.24, A.5.25, A.5.26, A.5.27, A.8.8, A.8.15, and A.8.16.
- **Third-Party and Supply Chain Risk** — Determine whether information security requirements are formally defined, included in supplier agreements, and actively monitored across all third-party relationships, in accordance with A.5.19, A.5.20, A.5.21, A.5.22, and A.5.23.
- **Privacy and Data Protection** — Verify whether the organization’s handling of personally identifiable information and payment data is subject to adequate technical and procedural controls, ensuring compliance with applicable data protection obligations, in accordance with A.5.12, A.5.14, A.5.34, A.8.11, and A.8.12.

5 Audit Plan

5.1 Scope

The scope of this engagement covers the systems, processes, and organizational units that support SecureCart’s e-commerce operations and the secure handling of customer and payment-related information.

In-scope systems and services

- Public e-commerce platform (web application, APIs, and customer account workflows).
- Cloud infrastructure hosting production and staging workloads (compute, storage, databases, and networking).
- Identity and access management components, privileged-access workflows, and authentication mechanisms.
- Logging, monitoring, vulnerability management, and backup/recovery supporting systems.
- Third-party services with direct security impact (payment gateway, cloud provider services, and outsourced development interfaces).

In-scope organizational processes and departments

- Engineering and DevOps: secure development, change management, deployment controls, and environment segregation.
- IT/Security and Compliance: policy governance, risk treatment, incident management, vulnerability handling, and monitoring.

- Customer Support and Finance operations: handling of customer records and payment-related workflows.
- Human Resources (security-relevant subset): onboarding, role change, and offboarding controls linked to access lifecycle.

Location and boundary definition

- Primary assessment boundary is SecureCart’s cloud-hosted environment and remote endpoints used by authorized staff.
- Physical controls are assessed only where they directly affect in-scope assets (for example, remote device handling and off-premises equipment).

Applicable ISO/IEC 27001:2022 controls

- All controls marked as applicable in the Statement of Applicability (SoA) in the Appendix.
- Primary focus for Milestone 1: Organizational controls (A.5) and Technological controls (A.8), with supporting People controls (A.6) and selected Physical controls (A.7) where relevant.

Explicit exclusions

- Internal physical security operations of external cloud providers (assessed indirectly through contractual assurances and audit reports).
- Full red-team activities and broad penetration testing campaigns (outside planning milestone scope).
- Forensic deep-dive investigations of historical incidents unless triggered by critical findings during fieldwork.

5.2 Methodology

This audit follows a risk-based approach aligned with ISO/IEC 27001:2022 requirements and the controls selected in the SoA.

Audit techniques

- **Interviews:** structured interviews with Engineering lead, DevOps lead, Security/Compliance owner, Customer Support manager, HR representative, and Finance/payment operations representative.

- **Document review:** policies and standards, risk register, asset inventory, access review records, supplier contracts and security clauses, incident records, vulnerability reports, backup/recovery evidence, and training records.
- **Process observation and walkthroughs:** user provisioning/deprovisioning, change approval, incident escalation, alert handling, vulnerability remediation, and backup restore test workflow.

Evidence collection, classification, and validation

- Evidence is collected through document requests, system screenshots/exports, interview notes, and control walkthrough records.
- Each evidence item is tagged by control reference, source, date, owner, and evidence type (policy, procedural, technical, or record-based evidence).
- Validation is performed by triangulation between policy, implementation proof, and operational records to confirm control effectiveness.
- Any contradictory or incomplete evidence is marked for follow-up and tracked until resolved or formally accepted as a limitation.

Gap classification model

- **Critical:** control absence or failure with immediate high risk to confidentiality, integrity, or availability, requiring urgent remediation.
- **Major:** significant control weakness or inconsistent implementation that materially increases security risk.
- **Minor:** localized or procedural weakness with limited impact, still requiring planned correction.
- **Observation:** improvement opportunity where baseline compliance exists but maturity can be strengthened.

Conformity criteria

- **Conformant:** control requirements are defined, implemented, and evidenced.
- **Partially conformant:** control exists but is incomplete, inconsistent, or weakly evidenced.
- **Nonconformant:** required control is missing, not implemented, or ineffective.
- **Not applicable:** justified exclusion consistent with scope and SoA.

5.3 Timeline

Week	Period	Activity	Outcome
Week 1	23/02/2026 – 01/03/2026	Review of the assignment requirements, analysis of the SecureCart Inc. scenario, and study of relevant ISO27001:2022 controls.	Understanding of the audit context and applicable security controls.
Week 2	02/03/2026 – 08/03/2026	Definition of the audit objectives, audit scope, and methodology to be used during the audit process.	Clear definition of audit objectives and audit approach.
Week 3	09/03/2026 – 15/03/2026	Preparation of the audit plan and organization of the audit timeline.	Completed Audit Plan deliverable.
Week 4 – 6	16/03/2026 – 05/04/2026	Audit execution: review of the company’s current security practices described in the scenario and comparison with ISO27001 requirements.	Identification of security gaps and potential compliance issues.
Week 7	06/04/2026 – 12/04/2026	Documentation of findings: organization of audit results and mapping of identified gaps to the corresponding ISO27001 controls.	Structured documentation of audit findings.
Week 8	13/04/2026 – 19/04/2026	Report preparation: compilation of audit results including methodology, findings, and recommendations.	Final audit report prepared for submission and presentation.

Table 1: Audit Planning and Execution Timeline

A Statement of Applicability Tables

A.1 Organizational Controls

Control	Name	SoA	Audit Question
A.5.1	Policies for Information Security	Yes	Are information security policies formally established, approved by management, communicated to all relevant personnel, and reviewed at planned intervals or following significant changes?
A.5.2	Information Security Roles and Responsibilities	Yes	Are information security roles and responsibilities clearly defined, formally assigned, and communicated across all departments, including IT, Operations, Finance, and Customer Support?
A.5.3	Segregation of Duties	Yes	Are conflicting duties and responsibilities adequately segregated to reduce the risk of unauthorized or unintentional modification of information assets, including in production and administrative access?
A.5.4	Management Responsibilities	Yes	Does management actively demonstrate commitment to information security by allocating resources, enforcing policies, and integrating security requirements into organizational processes?
A.5.5	Contact with Authorities	Yes	Are procedures in place to establish and maintain contact with relevant authorities - such as data protection regulators and law enforcement — in the event of information security incidents or legal obligations?
A.5.6	Contact with Special Interest Groups	Yes	Does the organization engage with relevant information security forums or special interest groups to remain informed about emerging threats and evolving best practices?
A.5.7	Threat Intelligence	Yes	Is there a formal process to collect, analyze, and act on threat intelligence relevant to the organization's assets and operational environment, including threats targeting e-commerce platforms and payment data?
A.5.8	Information Security in Project Management	Yes	Are information security requirements formally identified and addressed at all stages of project management, including platform development activities and integrations with third-party services?

Control	Name	SoA	Audit Question
A.5.9	Inventory of Information and Other Associated Assets	Yes	Is there a complete, accurate, and up-to-date inventory of all information assets — including cloud-based and dynamically provisioned resources — with assigned owners and defined classification levels?
A.5.10	Acceptable Use of Information and Other Associated Assets	Yes	Are acceptable use rules for information and organizational assets formally documented and communicated to all employees and contractors, including those operating under BYOD arrangements?
A.5.11	Return of Assets	Yes	Is there a formal process to ensure that all organizational assets — including devices, credentials, and access tokens — are returned or revoked upon termination or change of employment?
A.5.12	Classification of Information	Yes	Is information classified in accordance with defined classification levels that reflect its sensitivity and criticality, and is this classification consistently applied across all information assets and systems?
A.5.13	Labeling of Information	Yes	Are appropriate classification labels consistently applied to information assets in accordance with the organization's classification scheme, including customer data, payment records, and internal documentation?
A.5.14	Information Transfer	Yes	Are policies and controls in place to protect information during transfer — both within the organization and externally — including controls over local exports of customer datasets and the handling of payment information in support channels?
A.5.15	Access Control	Yes	Are access control policies formally established, implemented, and reviewed, ensuring that access to systems and information is granted and maintained in accordance with defined business and security requirements?
A.5.16	Identity Management	Yes	Is there a formal process for managing the full lifecycle of user identities — including timely provisioning and de-provisioning — covering all systems, including legacy systems with shared accounts?

Control	Name	SoA	Audit Question
A.5.17	Authentication Information	Yes	Are authentication credentials — including passwords and tokens — securely allocated, managed, and protected across all systems, with policies covering complexity, rotation, and revocation?
A.5.18	Access Rights	Yes	Are user access rights reviewed at regular intervals, and are excessive or unnecessary access rights — including those retained following role changes or terminations — revoked promptly?
A.5.19	Information Security in Supplier Relationships	Yes	Have information security requirements been formally identified and agreed for all supplier relationships, addressing risks arising from third-party access to organizational systems, data, and infrastructure?
A.5.20	Addressing Information Security Within Supplier Agreements	Yes	Do supplier agreements formally include information security requirements — covering responsibilities, obligations, and applicable controls — proportionate to the sensitivity of the data and systems involved?
A.5.21	Managing Information Security in the ICT Supply Chain	Yes	Are information security risks across the ICT supply chain identified and managed, including risks from software dependencies, outsourced development, and service providers with access to critical systems or sensitive data?
A.5.22	Monitoring, Review, and Change Management of Supplier Services	Yes	Are supplier services regularly monitored and reviewed, and are security-relevant changes to supplier services assessed, approved, and controlled to prevent adverse impact on SecureCart’s operations?
A.5.23	Information Security for Use of Cloud Services	Yes	Are information security requirements for cloud services formally defined, implemented, and monitored, including shared responsibility arrangements, access controls, logging, and data protection obligations?
A.5.24	Information Security Incident Management Planning and Preparation	Yes	Is there a formally documented and maintained incident management process, including defined roles, escalation paths, communication procedures, and preparedness activities such as playbooks and exercises?

Control	Name	SoA	Audit Question
A.5.25	Assessment and Decision on Information Security Events	Yes	Are information security events assessed in a timely and consistent manner using defined criteria to determine whether they constitute incidents and require escalation, response, or external notification?
A.5.26	Response to Information Security Incidents	Yes	Are incidents responded to through coordinated containment, eradication, and recovery actions, with responsibilities clearly assigned and actions tracked to closure?
A.5.27	Learning from Information Security Incidents	Yes	Are post-incident reviews conducted to identify root causes and lessons learned, and are corrective actions implemented to prevent recurrence and improve control effectiveness?
A.5.28	Collection of Evidence	Yes	Are procedures in place to collect, preserve, and handle evidence related to information security incidents in a manner that supports legal, regulatory, and disciplinary requirements?
A.5.29	Information Security During Disruption	Yes	Are information security controls maintained during disruptive events, ensuring critical processes continue operating securely under degraded conditions and emergency procedures?
A.5.30	ICT Readiness for Business Continuity	Yes	Is ICT readiness for business continuity established through defined recovery objectives, resilient architectures, tested recovery procedures, and periodic validation of continuity capabilities?
A.5.31	Legal, Statutory, Regulatory, and Contractual Requirements	Yes	Are all applicable legal, statutory, regulatory, and contractual information security requirements identified, documented, and translated into operational controls and compliance obligations?
A.5.32	Intellectual Property Rights	Yes	Are controls in place to protect intellectual property rights, including licensed software, proprietary code, and contractual restrictions on use, reproduction, and distribution of protected assets?

Control	Name	SoA	Audit Question
A.5.33	Protection of Records	Yes	Are records protected against loss, unauthorized access, alteration, and destruction, with retention and disposal periods defined in accordance with business, legal, and regulatory requirements?
A.5.34	Privacy and Protection of PII	Yes	Are privacy and protection measures for personally identifiable information formally implemented, including lawful processing, access limitation, retention control, and safeguards for customer and employee data?
A.5.35	Independent Review of Information Security	Yes	Is information security subject to periodic independent review to evaluate the adequacy, effectiveness, and continued suitability of policies, controls, and governance arrangements?
A.5.36	Compliance with Policies and Standards	Yes	Is compliance with information security policies, standards, and procedures regularly verified, and are nonconformities formally reported, tracked, and remediated?
A.5.37	Documented Operating Procedures	Yes	Are operating procedures for security-relevant activities documented, approved, maintained, and made available to personnel to ensure consistent and controlled execution of critical tasks?

Table 2: Organizational Controls — SoA and Audit Questions

A.2 People Controls

Control	Name	SoA	Audit Question
A.6.1	Screening	Yes	Are background verification checks conducted on all candidates for employment, including contractors, proportional to the business requirements and the classification of information to be accessed?
A.6.2	Terms and Conditions of Employment	Yes	Do employment agreements require employees and contractors to comply with the organization's information security policies and procedures?
A.6.3	Information Security Awareness, Education, and Training	Yes	Is there an ongoing information security awareness and training program in place for all employees and contractors, covering their security responsibilities?
A.6.4	Disciplinary Process	Yes	Is there a formal disciplinary process in place for employees and contractors who commit information security policy violations?
A.6.5	Responsibilities After Termination or Change of Employment	Yes	Are there formal procedures in place to ensure that information security responsibilities and access rights are properly managed upon termination or change of employment?
A.6.6	Confidentiality or Non-Disclosure Agreements	Yes	Are employees and contractors required to sign confidentiality or non-disclosure agreements before being granted access to sensitive information?
A.6.7	Remote Working	Yes	Are formal security policies in place for remote working, including measures to protect information accessed outside the organization's premises, such as encryption or VPN usage?
A.6.8	Return of Assets	Yes	Is there a formal process to ensure that all organizational assets, such as laptops and access credentials, are returned when an employee leaves or changes role?

Table 3: People Controls — SoA and Audit Questions

A.3 Physical Controls

Control	Name	SoA	Audit Question
A.7.1	Physical Security Perimeter	N/A	
A.7.2	Physical Entry Controls	N/A	
A.7.3	Securing Offices, Rooms, and Facilities	N/A	
A.7.4	Protecting Against External and Environmental Threats	N/A	
A.7.5	Working in Secure Areas	N/A	
A.7.6	Delivery and Loading Areas	N/A	
A.7.7	Equipment Siting and Protection	N/A	
A.7.8	Supporting Utilities	N/A	
A.7.9	Cabling Security	N/A	
A.7.10	Equipment Maintenance	N/A	
A.7.11	Removal of Assets	N/A	
A.7.12	Security of Equipment and Assets Off-Premises	Yes	Are security measures in place to protect organizational assets and devices used outside the organization's premises, including laptops and personal devices used by remote employees and contractors?
A.7.13	Secure Disposal or Reuse of Equipment	N/A	
A.7.14	Unattended User Equipment	Yes	Are users required to lock or log off unattended devices, including personal devices used under BYOD arrangements, to prevent unauthorized access?

Table 4: Physical Controls — SoA and Audit Questions

N/A – Excluded: SecureCart operates a fully cloud-hosted infrastructure with no dedicated physical information processing facilities. Physical security responsibilities fall on the cloud provider.

A.4 Technological Controls

Control	Name	SoA	Audit Question
A.8.1	User Endpoint Devices	Yes	Are security measures in place to protect user endpoint devices, such as laptops and mobile devices, including those used by remote employees and developers under BYOD arrangements?
A.8.2	Privileged Access Rights	Yes	Is the allocation and use of privileged access rights restricted, controlled, and regularly reviewed across all systems, including legacy systems and production environments?
A.8.3	Information Access Restriction	Yes	Are access restrictions in place to ensure that users, including developers and third-party contractors, only have access to the information and systems required for their specific role?
A.8.4	Access to Source Code	Yes	Is access to source code repositories restricted and controlled, ensuring that only authorized personnel, including third-party developers, are granted the necessary level of access?
A.8.5	Secure Authentication	Yes	Are secure authentication mechanisms, including multi-factor authentication, enforced across all systems and applications, including internal cloud dashboards and remote access solutions?
A.8.6	Capacity Management	Yes	Are capacity demands of systems and infrastructure monitored to ensure adequate performance and availability?
A.8.7	Protection Against Malware	Yes	Are detection, prevention, and recovery controls implemented across all systems and endpoints to protect against malware, including devices used for remote access?
A.8.8	Management of Technical Vulnerabilities	Yes	Is there a formal process to identify, assess, and remediate technical vulnerabilities across all systems, applications, and cloud infrastructure in a timely manner?
A.8.9	Configuration Management	Yes	Are configurations of hardware, software, services, and networks formally documented, implemented, and maintained across all systems and cloud infrastructure?

Control	Name	SoA	Audit Question
A.8.10	Information Deletion	Yes	Are there formal policies and procedures in place to ensure the secure and timely deletion of information when it is no longer required, across all systems and storage solutions?
A.8.11	Data Masking	Yes	Is data masking applied to protect sensitive information, such as payment data and personal customer details, particularly in non-production environments?
A.8.12	Data Leakage Prevention	Yes	Are data leakage prevention measures in place to detect and prevent unauthorized transmission of sensitive information, such as customer personal data and payment information?
A.8.13	Information Backup	Yes	Are backup copies of information, software, and system images taken and tested regularly in accordance with a defined backup policy, ensuring the recoverability of critical business data?
A.8.14	Redundancy of Information Processing Facilities	Yes	Are redundant information processing facilities in place to ensure the availability of critical systems and services in the event of a failure?
A.8.15	Logging	Yes	Are event logs recorded, protected, and retained across all systems and applications in accordance with a defined log retention policy?
A.8.16	Monitoring Activities	Yes	Are networks and systems continuously monitored to detect anomalies, unauthorized access, and potential security incidents across all systems and cloud infrastructure?
A.8.17	Clock Synchronization	Yes	Are the clocks of all information processing systems, including endpoint devices and any on-premises infrastructure, synchronized to a single reference time source to ensure accurate event correlation?
A.8.18	Use of Privileged Utility Programs	Yes	Is the use of utility programs that could override system and application controls restricted, monitored, and authorized across all systems and infrastructure?

Control	Name	SoA	Audit Question
A.8.19	Installation of Software on Operational Systems	Yes	Are there formal procedures to control and authorize the installation of software on operational systems, preventing the deployment of unauthorized or untested software?
A.8.20	Networks Security	Yes	Are networks managed and controlled to protect information in systems and applications, including segmentation between internal networks, cloud infrastructure, and third-party connections?
A.8.21	Security of Network Services	Yes	Are security features, service levels, and management requirements of network services — including those provided by third parties such as cloud providers and payment gateways — formally identified and included in service agreements?
A.8.22	Segregation of Networks	Yes	Are different groups of information services, users, and systems segregated on separate networks, ensuring isolation between production, development, and third-party environments?
A.8.23	Web Filtering	Yes	Are controls implemented to restrict access to inappropriate or malicious websites across all systems and devices used by employees and contractors?
A.8.24	Use of Cryptography	Yes	Are cryptographic controls formally defined and applied to protect sensitive information, including customer personal data and payment information, both in transit and at rest?
A.8.25	Secure Development Life Cycle	Yes	Is information security formally integrated into the software development life cycle, ensuring that security requirements are identified and addressed at every stage of development, from design to deployment?
A.8.26	Application Security Requirements	Yes	Are security requirements formally identified, specified, and documented as part of the development process for all applications, including the e-commerce platform and integrations with third-party services such as payment gateways?

Control	Name	SoA	Audit Question
A.8.27	Secure System Architecture and Engineering Principles	Yes	Are secure engineering principles formally established, documented, and applied when designing and implementing information systems, including the e-commerce platform and cloud infrastructure?
A.8.28	Secure Coding	Yes	Are secure coding principles and best practices formally defined and applied by all developers, including third-party contractors, throughout the software development process?
A.8.29	Security Testing in Development and Acceptance	Yes	Are security tests formally conducted during development and prior to acceptance of new systems and updates, including the e-commerce platform and integrations with third-party services?
A.8.30	Outsourced Development	Yes	Is outsourced software development supervised and monitored to ensure that security requirements are met, and are appropriate security obligations formally included in contracts with external developers?
A.8.31	Separation of Development, Test, and Production Environments	Yes	Are development, testing, and production environments formally separated to prevent unauthorized access, unintended changes, or exposure of sensitive data?
A.8.32	Change Management	Yes	Are changes to information systems, applications, and infrastructure controlled through a formal change management process, ensuring that all changes are assessed, authorized, and tested prior to implementation?
A.8.33	Test Information	Yes	Is test data carefully selected, protected, and controlled, ensuring that sensitive information such as customer personal data and payment details is not used in testing environments?
A.8.34	Protection of Information Systems During Audit and Testing	Yes	Are audit and testing activities formally planned and agreed upon to minimize disruption and risks to operational systems and services?

Table 5: Technological Controls — SoA and Audit Questions